🌐 Module 05: Web Application Penetration Testing

```
# Exercise 9: Web Application Vulnerability Assessment Using Zed Attack Proxy (ZAP)
```

Scenario

Zed Attack Proxy (ZAP) is an integrated penetration testing tool for discovering vulnerabilities in web applications. It offers automated scanners as well as a comprehensive suite of manual testing tools.

The objective of this lab is to help students learn how to perform automated web application vulnerability assessments using OWASP ZAP. The vulnerability scanner tests various payloads against the target application. In real-world environments, scanning must be performed in pre-production or staging environments to prevent service disruption.

Objective

The objective of this lab is to help students learn how to:
- Perform automated web application vulnerability scanning using OWASP ZAP
- Analyze High-severity security alerts (Persistent XSS, MS-SQL Injection)
- Extract raw POST request payloads for offline analysis and manual exploitation

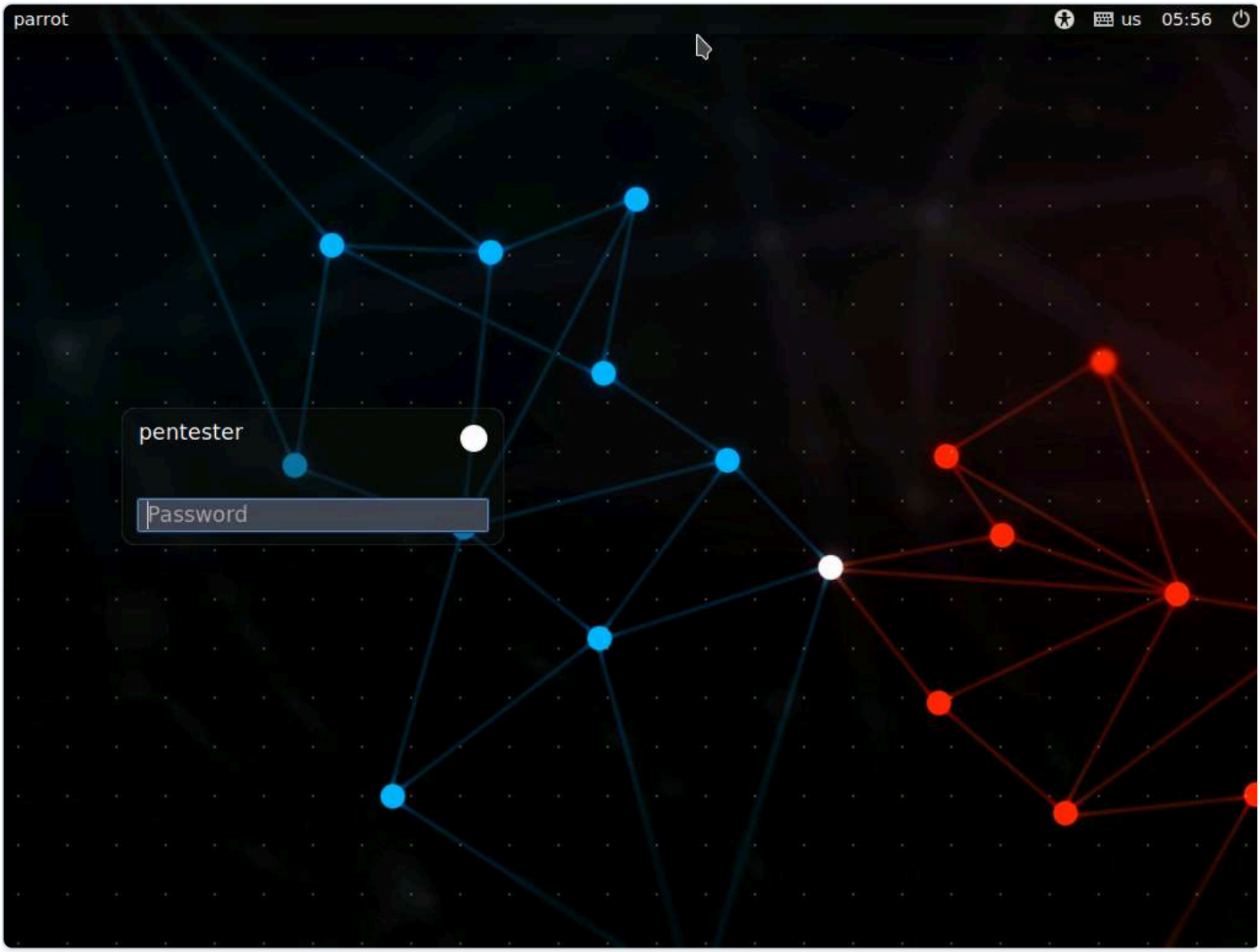
---

Task 1: Web Application Vulnerability Assessment Using Zed Attack Proxy (ZAP)

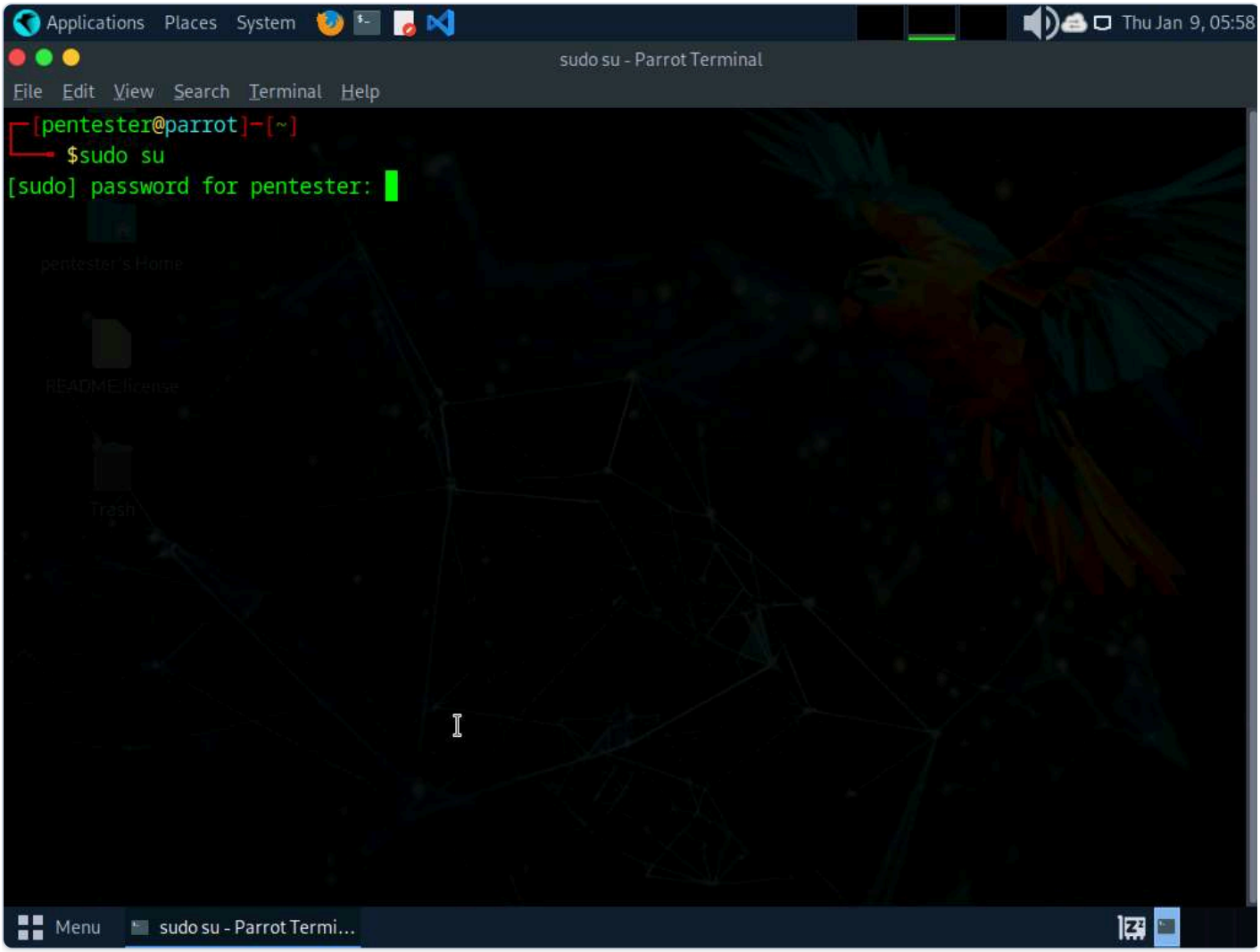
In this task, we perform an automated security scan against `www.luxurytreats.com` using OWASP ZAP, examine identified High-severity vulnerabilities, and extract the vulnerable POST request body to a local file for subsequent exploitation.

Lab Tasks

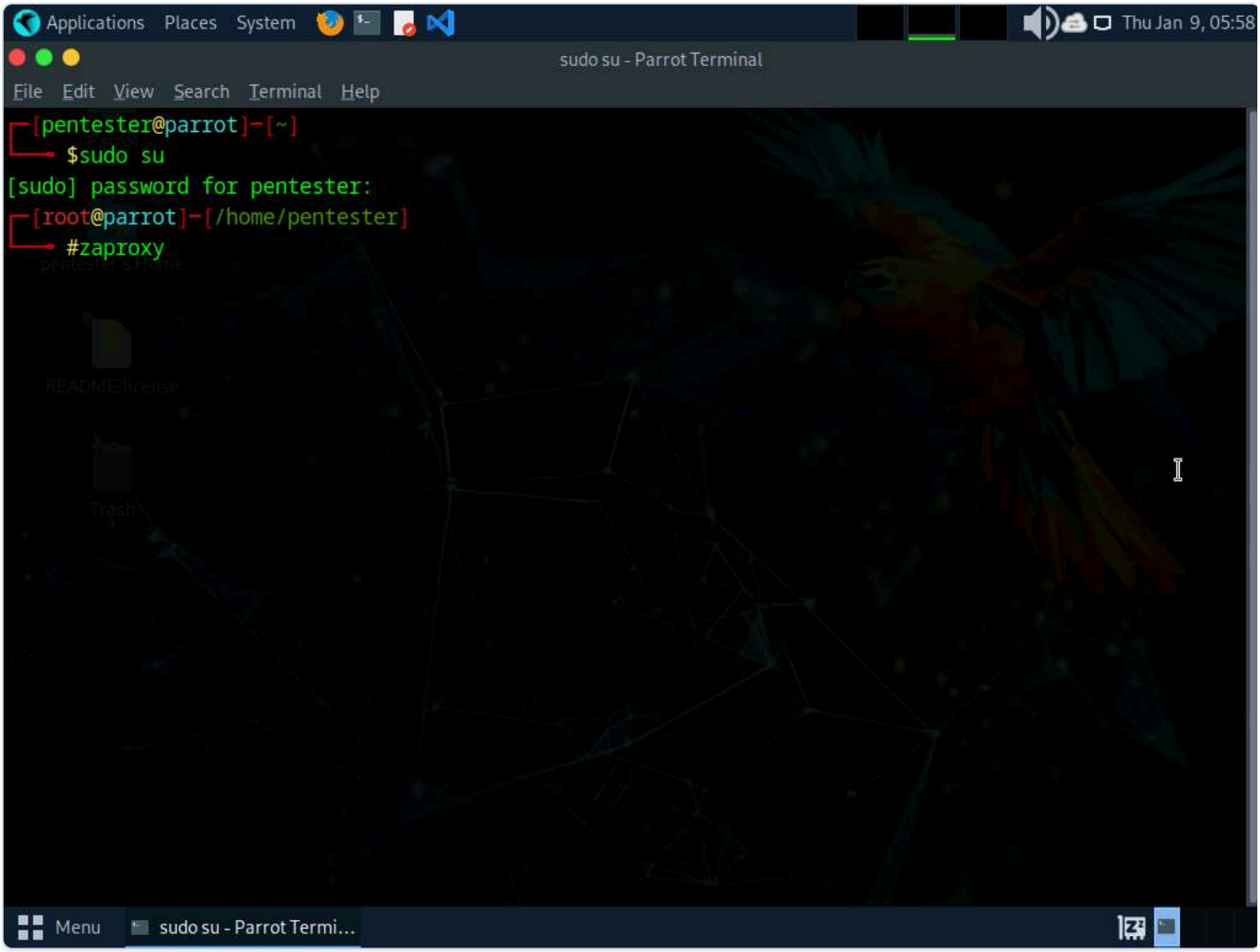
1. Click **Parrot Security**. Type **toor** in the Password field and press Enter.



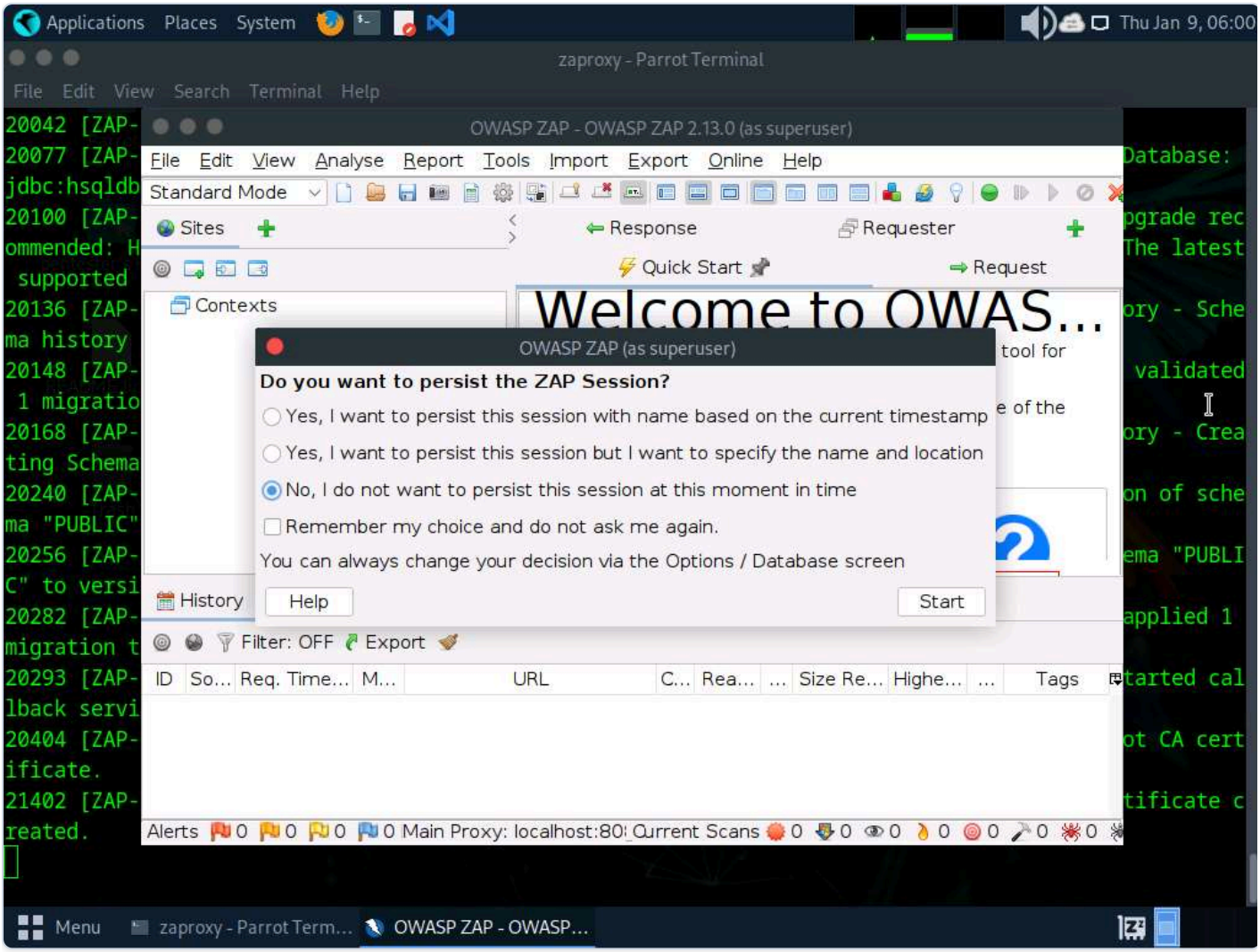
1. Launch a command-line terminal, type **sudo su**, and press Enter. Enter **toor** as the password.



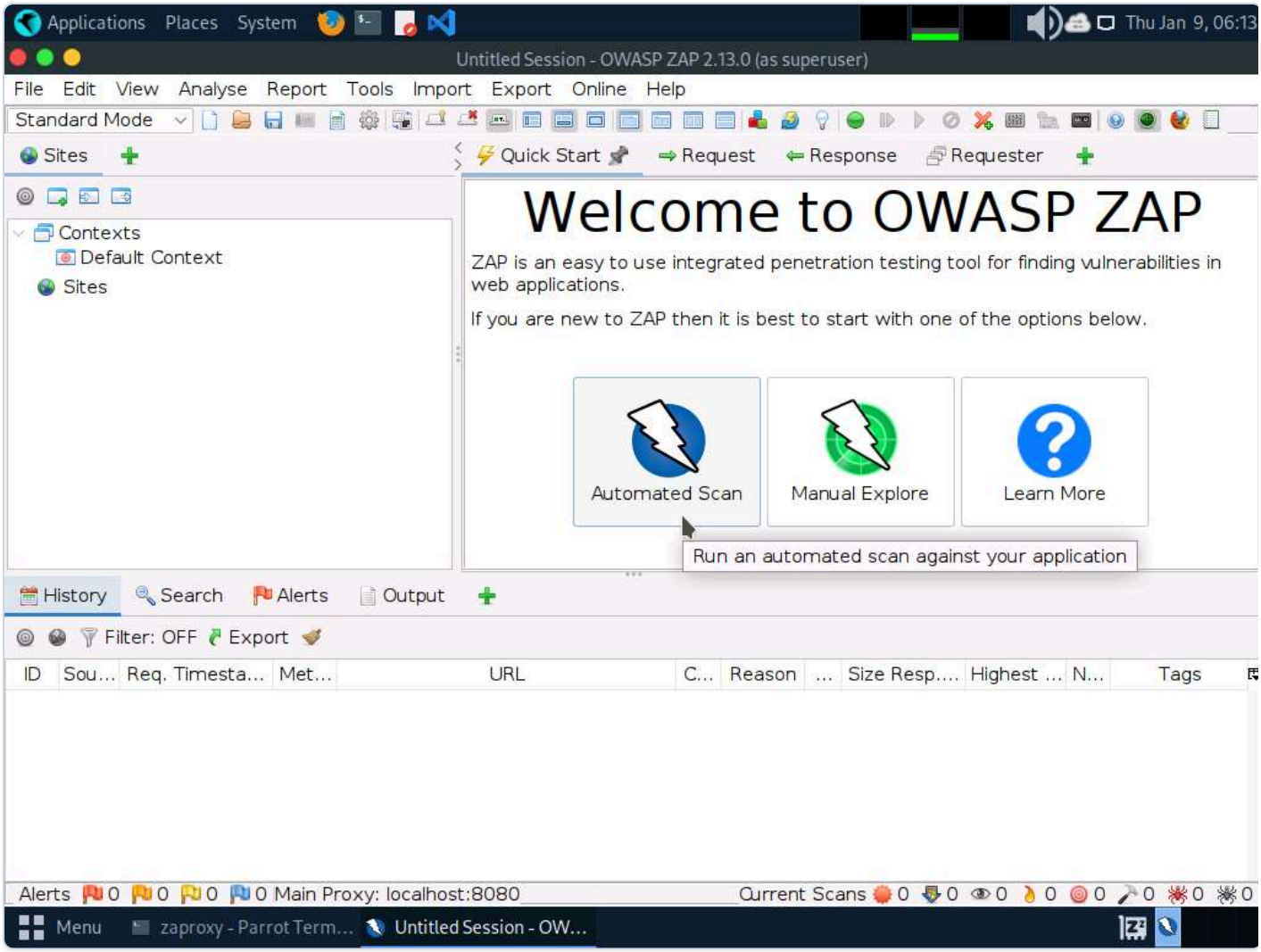
1. In the Terminal window, type **zaproxy** and press Enter to launch OWASP ZAP.



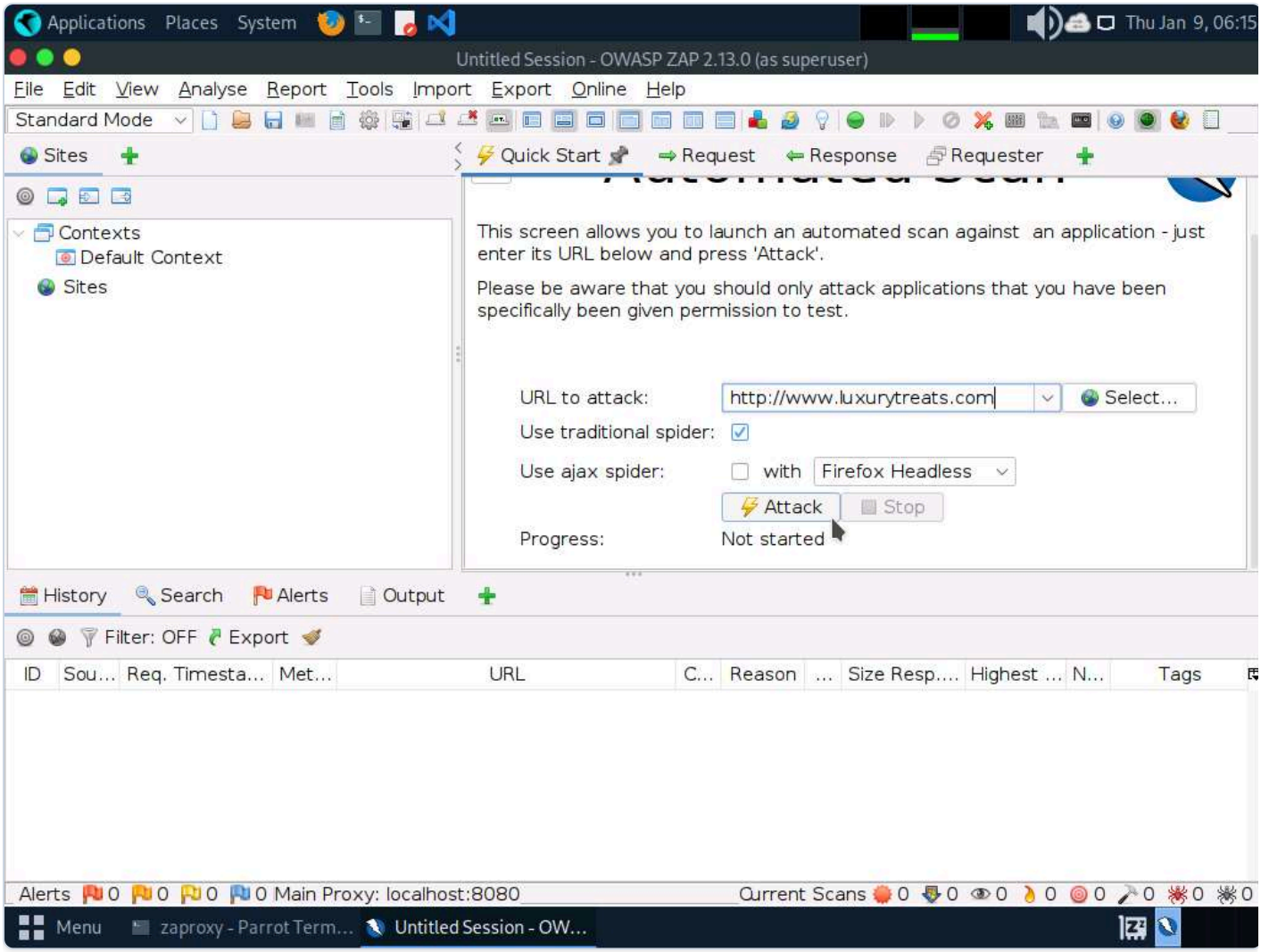
1. The OWASP ZAP initialization window appears; wait for initialization to complete.
2. When prompted with *Do you want to persist the ZAP Session?*, select **No, I do not want to persist this session at this moment in time** and click **Start**.
3. *(If a Manage Add-ons window appears, close it.)*



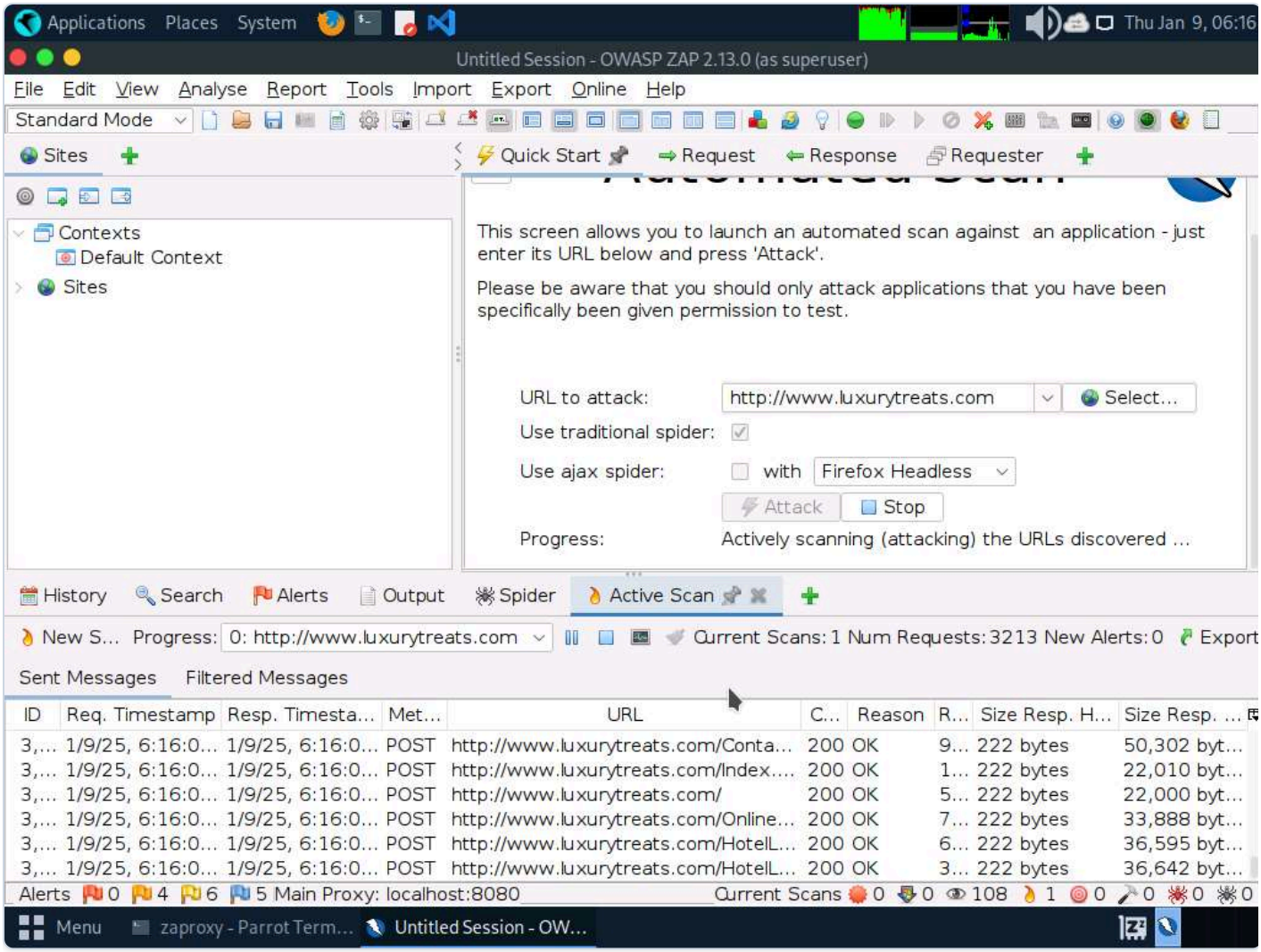
1. On the OWASP ZAP main interface, under the **Quick Start** tab, click **Automated Scan**.



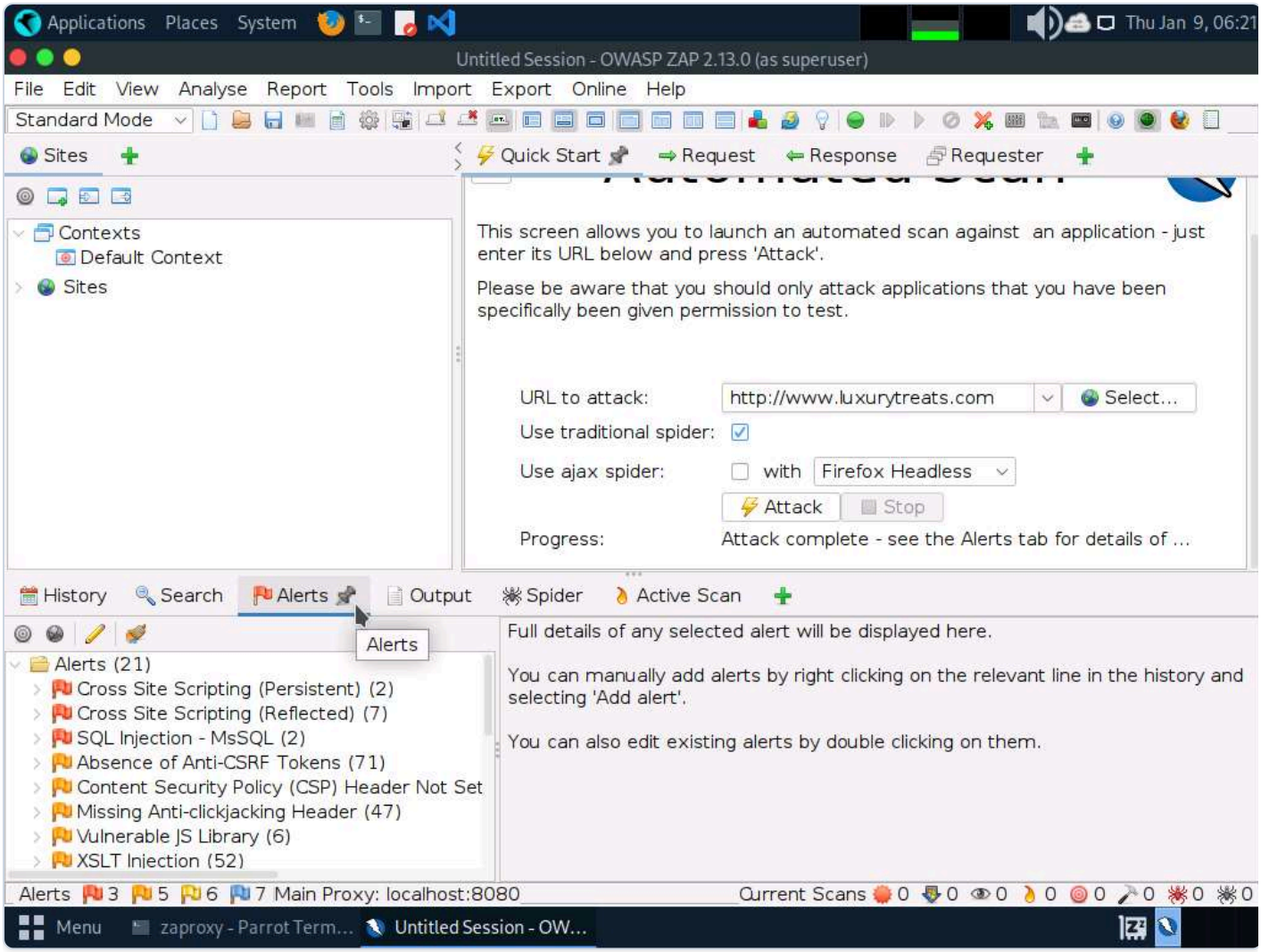
1. In the Automated Scan wizard, enter **www.luxurytreats.com** under the **URL to attack** field. Leave default settings and click **Attack**.



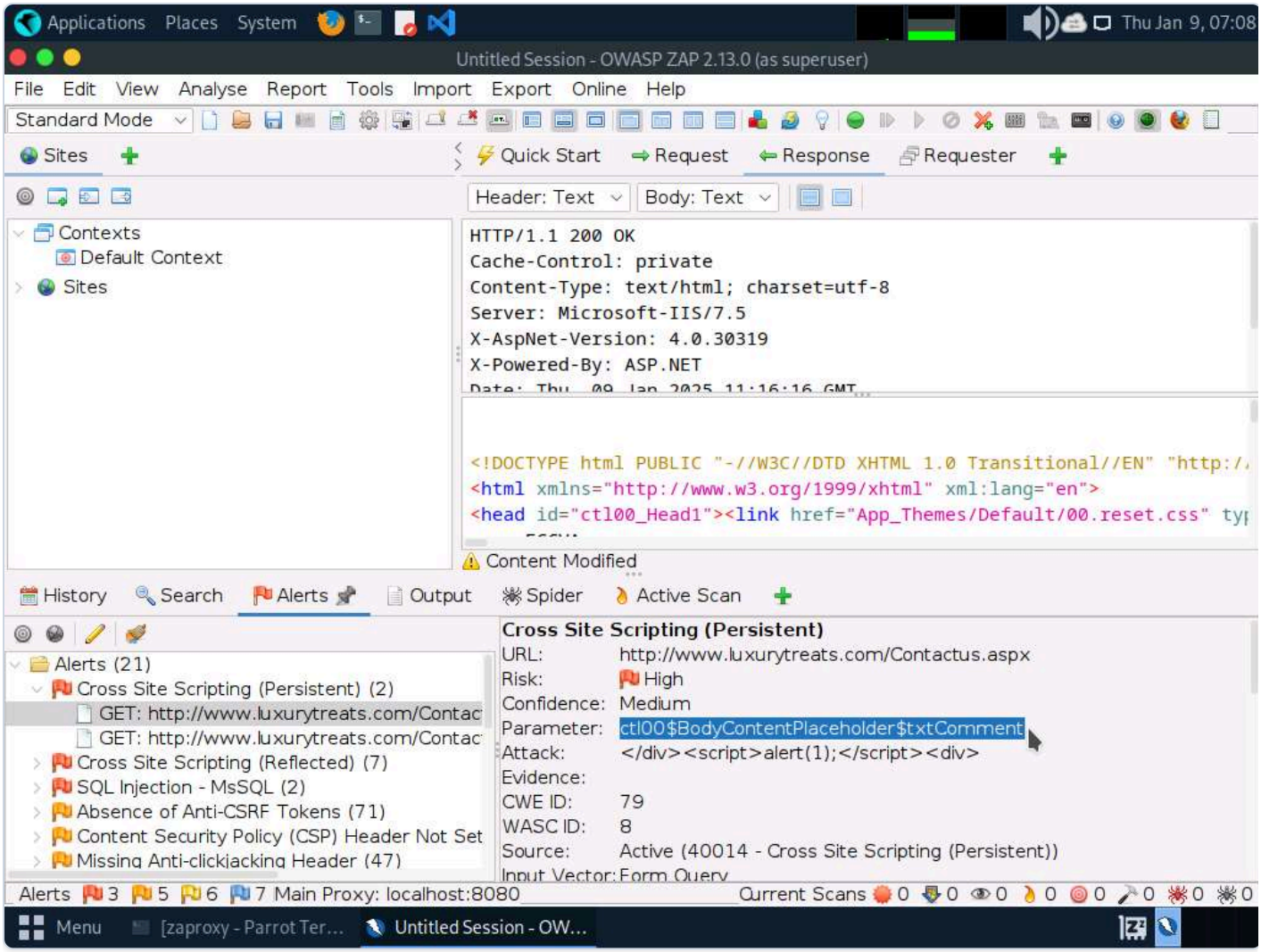
1. ZAP initiates active scanning against the target. Discovered URLs display under the **Active Scan** tab.

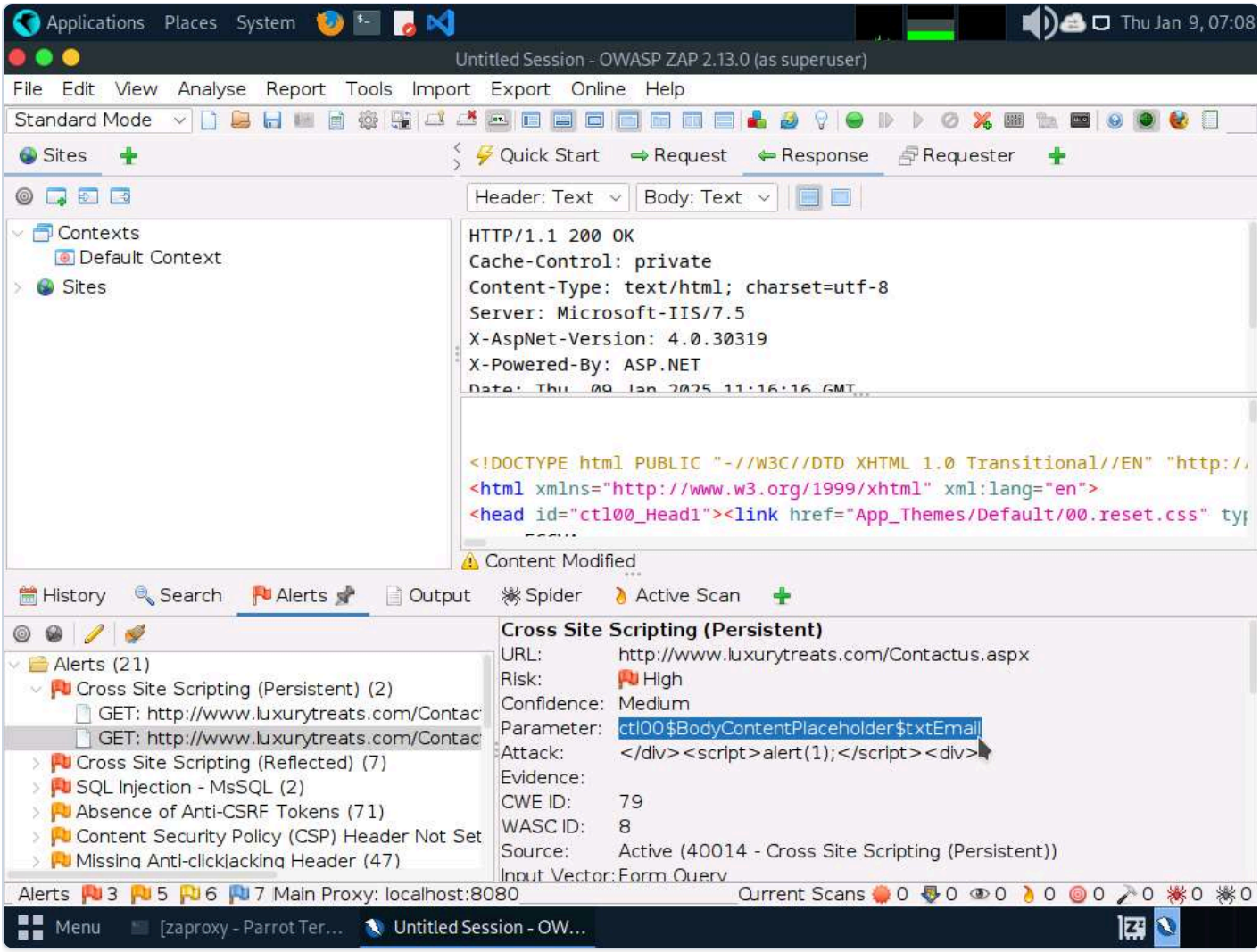


1. As scanning progresses, alert counters for **High**, **Medium**, **Low**, and **Informational** severities increment. After scanning for approximately 5 minutes, click the **Alerts** tab.

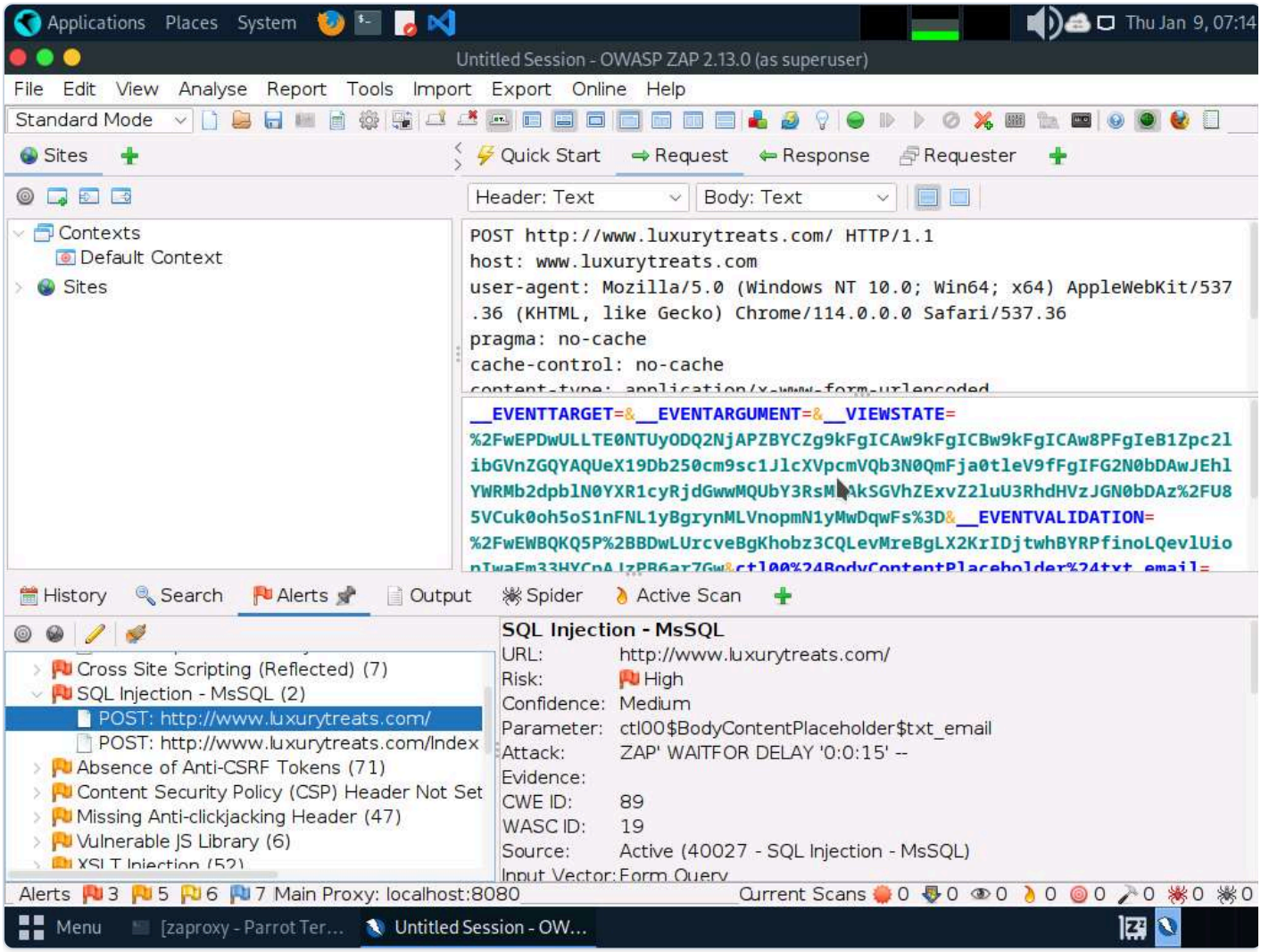


1. Expand the **Cross-Site Scripting (Persistent)** node and select sub-nodes to inspect vulnerable endpoints (e.g., `http://www.luxurytreats.com/ContactUs.aspx` within the `Email` and `Comment` fields).

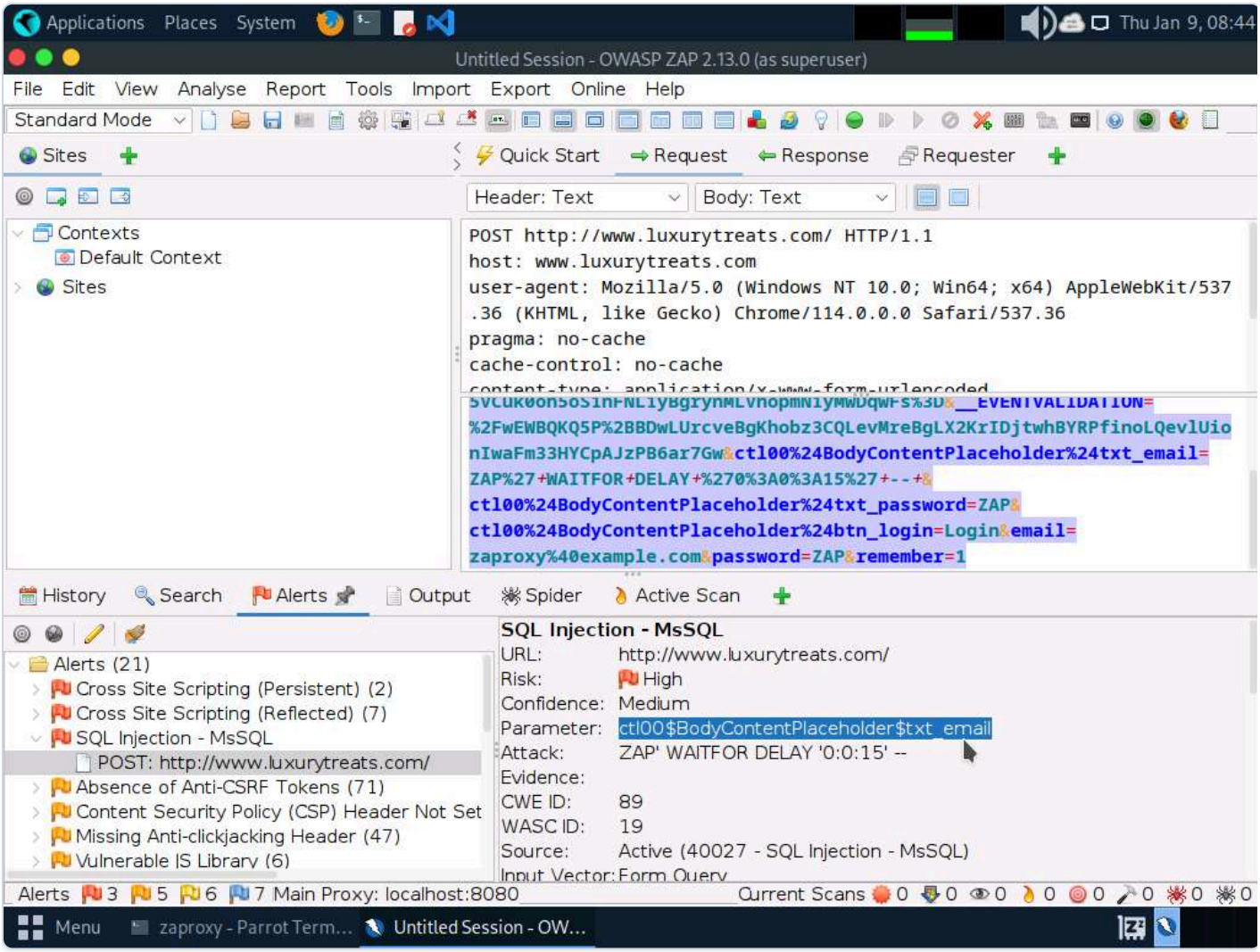

Applications Places System
Thu Jan 9, 07:08
Untitled Session - OWASP ZAP 2.13.0 (as superuser)
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Header: Text
Body: Text
Contexts
Default Context
Sites
HTTP/1.1 200 OK
Cache-Control: private
Content-Type: text/html; charset=utf-8
Server: Microsoft-IIS/7.5
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http:/
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en">
<head id="ctl00_Head1"><link href="App_Themes/Default/00.reset.css" ty
Content Modified
History
Search
Alerts
Output
Spider
Active Scan
Alerts (21)
Cross Site Scripting (Persistent) (2)
GET: http://www.luxurytreats.com/Contac
GET: http://www.luxurytreats.com/Contac
Cross Site Scripting (Reflected) (7)
SQL Injection - MsSQL (2)
Absence of Anti-CSRF Tokens (71)
Content Security Policy (CSP) Header Not Set
Missing Anti-clickjacking Header (47)
Cross Site Scripting (Persistent)
URL: http://www.luxurytreats.com/Contactus.aspx
Risk: High
Confidence: Medium
Parameter: ctl00$BodyContentPlaceholder$txtComment
Attack: <script>alert(1);</script>
Evidence:
CWE ID: 79
WASC ID: 8
Source: Active (40014 - Cross Site Scripting (Persistent))
Input Vector: Form Query
Alerts 3 5 6 7 Main Proxy: localhost:8080
Current Scans 0 0 0 0 0 0 0 0
Menu
[zaproxy - Parrot Ter...
Untitled Session - OW...



1. Expand the **SQL Injection - MsSQL** node to view the SQL Injection alert details. Observe that OWASP ZAP assigns a risk rating of **High** to this vulnerability.

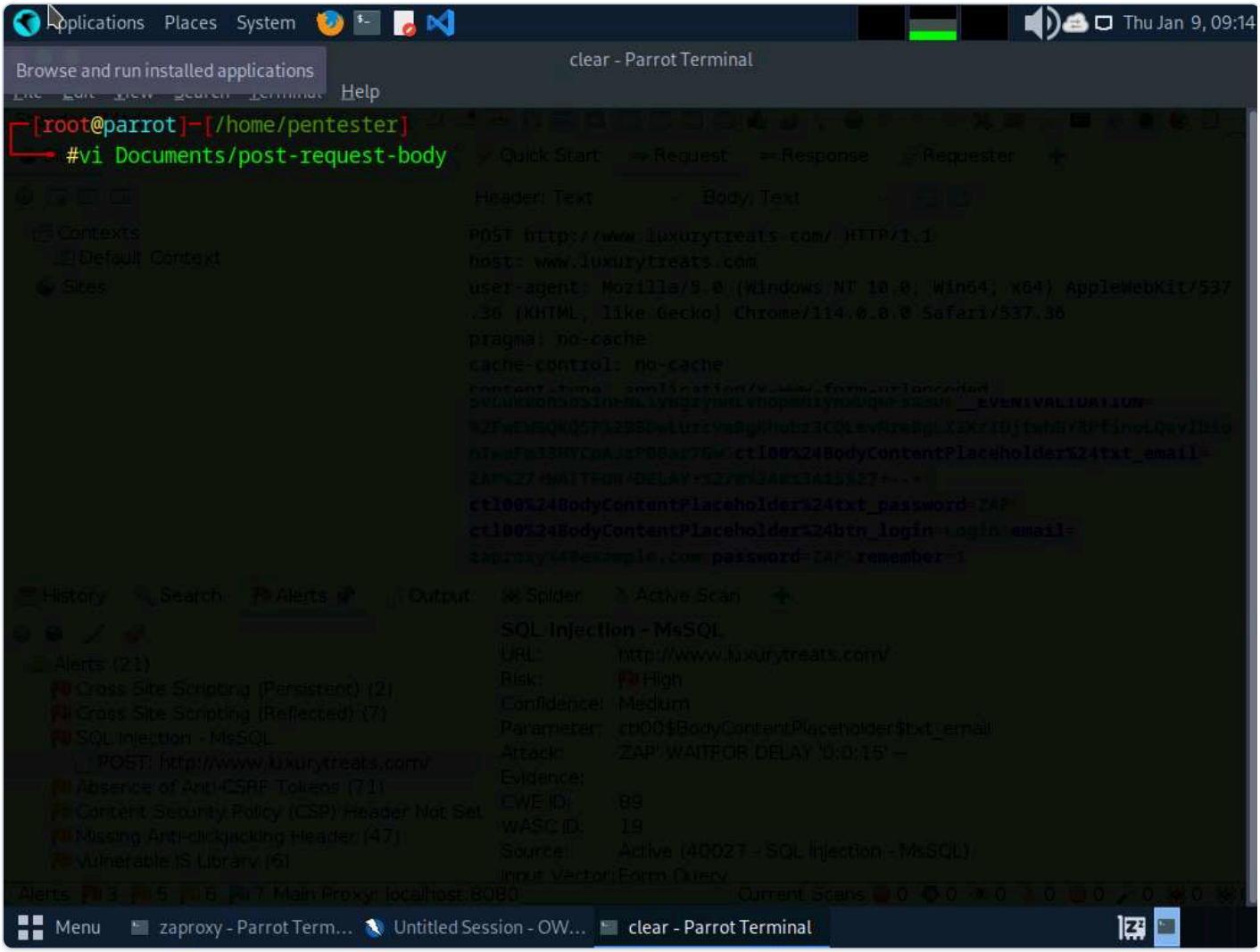


1. Click the **Request** button on the top panel to view the raw HTTP POST request that triggered the alert. Copy the raw POST request body.

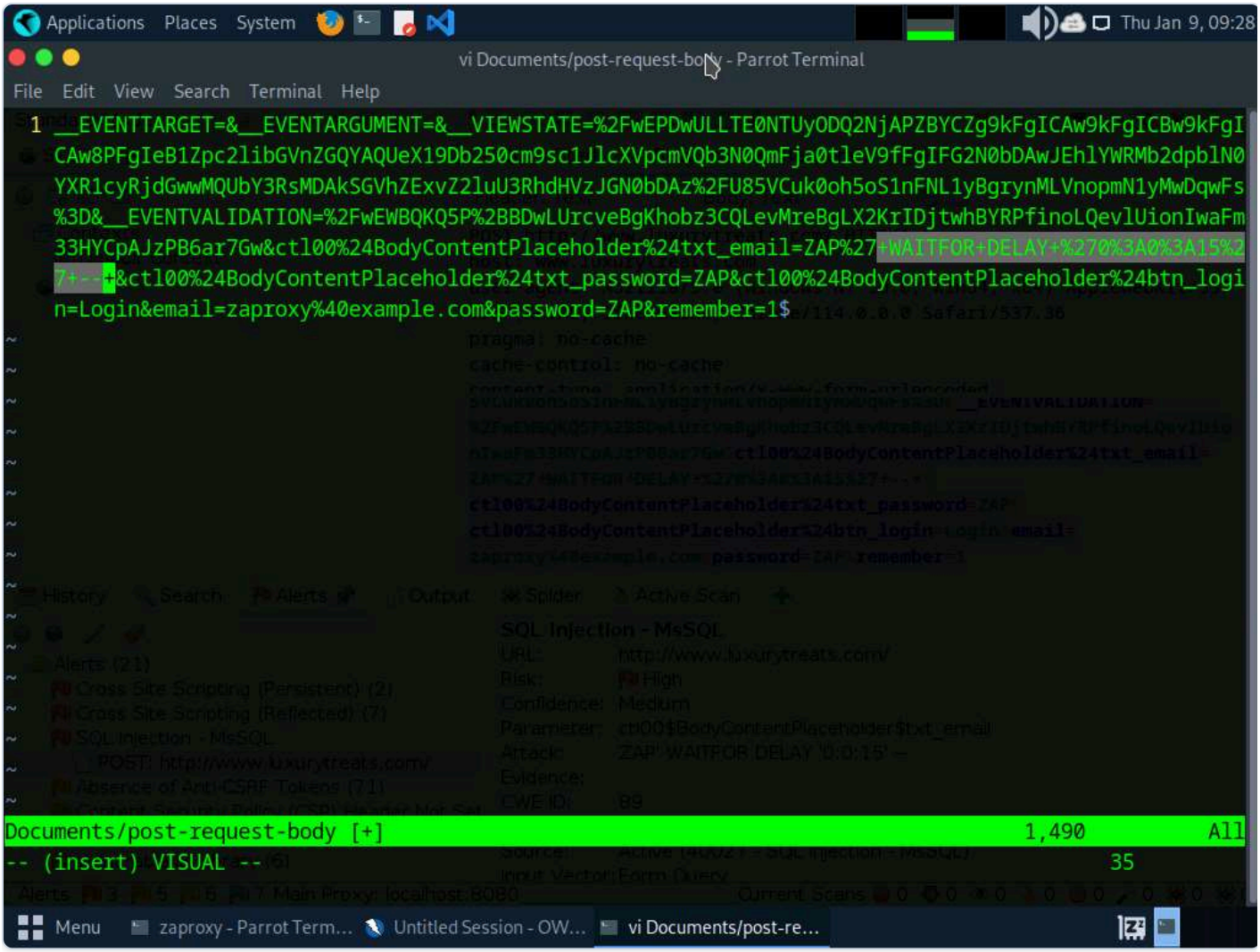


1. Create a text file named **post-request-body** in the `Documents` directory using a text editor (e.g., `vim`) and paste the copied POST request content.

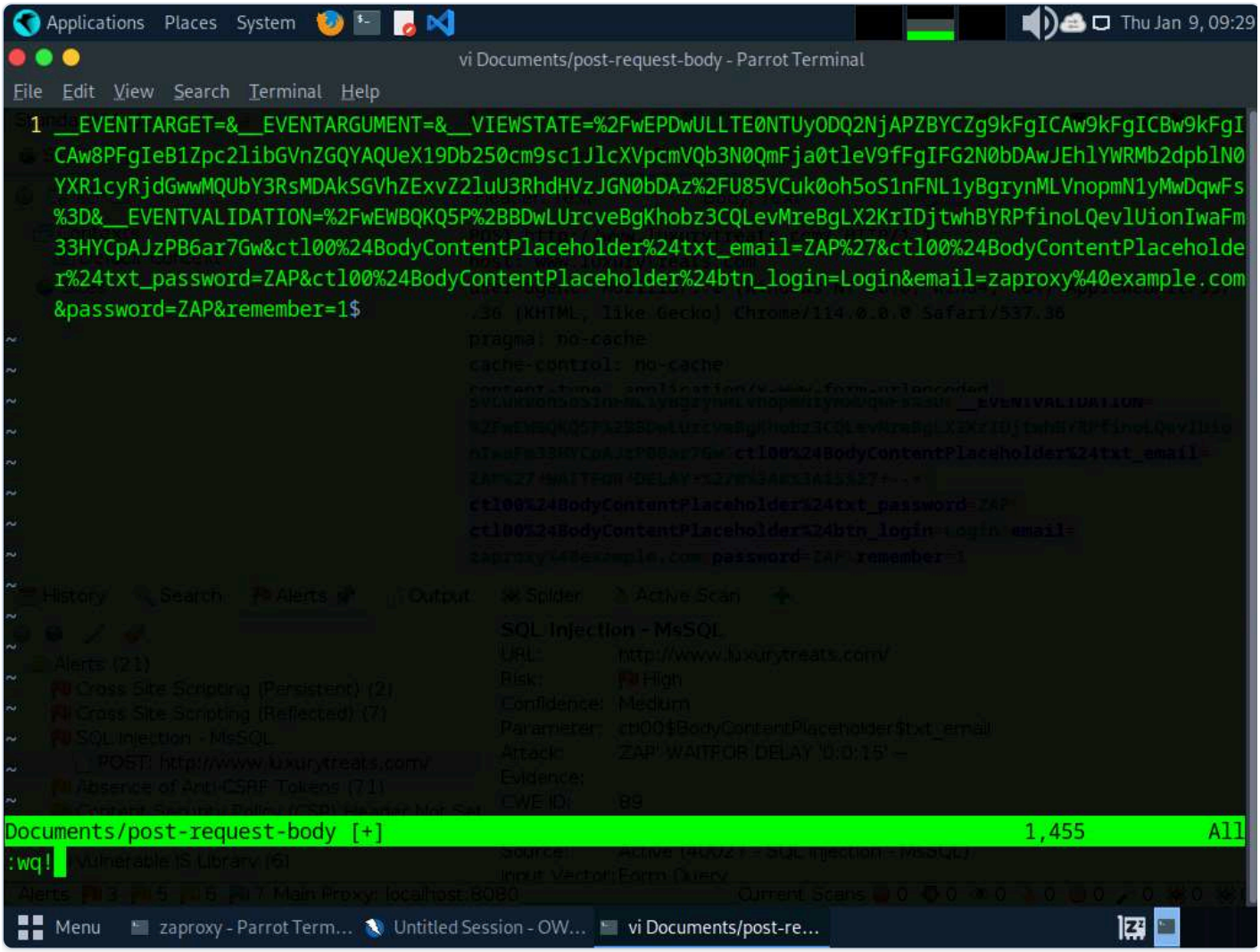
> **TIP:** 📁 **Local Repository Asset**: In your local environment, this extracted POST request file is stored under: `CPENTv2 Pen Testing Resources/CPENTv2 Scripts/Module 05 Web Application Penetration Testing/post-request-body`



1. Modify the parameter value for `ctl00$BodyContentPlaceholder$txt_email` to **ZAP%27** (representing `ZAP'`) by stripping the extended payload string.



1. Save the **post-request-body** file.



1. Close all windows. *(Do not terminate the target service, as Exercise 05.10 continues from this state).*

This concludes the lab exercise.

IMPORTANT: ❓ **Question 5.9.1.1** From the Parrot Security machine, conduct a web application vulnerability assessment on `www.luxurytreats.com` using the Zed Attack Proxy (ZAP) tool with the Automated Scan option. Capture the POST content from the request body associated with any identified SQL Injection vulnerability and save it. Finally, document the Risk Rating assigned to the SQL Injection vulnerability after the scan. [!SUCCESS] ✅
Answer: **High** (or **high**)